

TRIAGE-LINK — Regulatory & Privacy

Decision Brief

Purpose. A decision-oriented brief on the two questions that gate everything else when commercializing: **(1) Is it a medical device?** and **(2) How do we lawfully handle PHI?** Distilled from `docs/CERTIFICATION-ROADMAP.md` (the full standards stack) for fast decision-making. One of three exploration deliverables.

⚠ Not legal or regulatory advice. Classification and privacy obligations are product-, claim-, and jurisdiction-specific. Engage a regulatory-affairs professional and a health-privacy lawyer **before** any real-PHI deployment.

Prepared 2026-06-27.

Decision 1 — Medical device, or documentation tool?

This single intended-use choice determines cost, timeline, and which customers you can serve.

	Documentation / coordination tool	Software as a Medical Device (SaMD)
What it claims	Captures, organizes, and transmits what a clinician decides	Software that drives or informs clinical decisions
Trigger in our product	TBSA/START shown as user-entered, clinician-confirmed records	TBSA/START presented as clinical guidance the user acts on
Regulatory burden	Light — privacy + general software quality	Heavy — design controls, ISO 14971, IEC 62304/62366, clinical evaluation, Health Canada/FDA
Time to first revenue	Months	12-24+ months
Cost	Modest	Six-figures-plus + ongoing QMS
Best for	Humanitarian / disaster / event beachhead	Official EMS / regulated channel

Recommendation (for the niche-first strategy): adopt the **documentation-tool** intended use. Write a tight **Intended Use / Indications for Use** statement, and ensure computed outputs (Lund-Browder **TBSA, START** category) are presented as **records the clinician confirms**, not as automated guidance. Revisit only when deliberately entering the regulated/EMS channel (strategy Phase 3).

⚠ **Watch for scope creep.** Today's prototype already *computes* acuity-adjacent values. UI wording and framing are what tip it from "tool" into "SaMD" — keep them on the record-keeping side until you choose otherwise.

Decision 2 — Lawful PHI handling (required even as a documentation tool)

Handling real patient data triggers privacy law regardless of device classification.

Canadian baseline

- **PHIPA** (Ontario) and equivalent **provincial health-privacy acts**; **PIPEDA** federally. Expect: lawful basis, consent/notice, access/correction rights, **safeguards**, **breach notification**, and a **data-retention/destruction** policy.
- **Data residency**: many Canadian health customers require PHI stored **in Canada** — design hosted/sync tiers with a Canadian region option (the offline-first default keeps data on-device, which *helps* but doesn't remove the obligation once you offer sync).
- **DPA / agreements**: customers will expect a Data Processing Agreement and a documented security posture.

If you go international (likely, given the humanitarian beachhead)

- **GDPR** (EU/EEA data subjects), plus humanitarian-sector norms — e.g. **ICRC / Handbook on Data Protection in Humanitarian Action** expectations for vulnerable populations.
- Cross-border transfer and "do no harm" data-minimization are scrutinized in this sector; the **on-device, no-backend** default is a genuine selling point here.

US (only if entering that market)

- **HIPAA** Privacy & Security Rules; Business Associate Agreements. Treat as Phase 2+/3.

Security controls expected (productize from the prototype)

These are the controls customers and auditors look for — several are already partly built:

Control	Status today	Needed for
Encryption at rest (AES-256-GCM)	✅ built, opt-in	Make always-on by org policy
Encryption in transit (TLS)	✅ (sync service)	Standard
RBAC + least privilege	❌	Org tier
Immutable audit log	❌	PHIPA/HIPAA-grade accountability
Authentication / SSO	❌	Org/Enterprise
Retention & destruction tooling	❌	Privacy compliance
Breach-detection + response process	❌ (process, not code)	All real-PHI use
SOC 2 Type II / pen test	❌	Enterprise/government

(Engineering detail and sizing in [docs/productization-gap-backlog.md](#) §2.)

Health Canada pathway (only if/when SaMD)

- Likely **Class II** medical device if classified as SaMD (influences clinical decisions but not life-sustaining). Requires an **ISO 13485 QMS**, a **Medical Device Licence**, and the standards stack (IEC 62304 software lifecycle, ISO 14971 risk, IEC 62366 usability, IEC 81001-5-1 cybersecurity) plus a **clinical evaluation**.
- **FDA (US)**: typically a **510(k)** route for a comparable predicate. **EU: MDR** with a Notified Body. All are Phase 3 decisions.
- Full detail, phased plan, and indicative cost/timeline live in [docs/CERTIFICATION-ROADMAP.md](#) — this brief intentionally does not duplicate it.

Bottom line & recommended posture

1. **Lock intended use = documentation/coordination tool** → stay on the light path for the beachhead.
2. **Do the privacy work now anyway** (policy, DPA, residency option, retention, breach process) — it's required the moment you touch real PHI, even as a tool.
3. **Productize the security controls** (always-on encryption, RBAC, audit, SSO) — they're procurement gates *and* the foundation a future SaMD submission reuses.
4. **Defer the SaMD/Health Canada stack** to a deliberate, funded Phase-3 decision when entering the regulated/EMS channel.

If you choose...	Regulatory path	First-revenue horizon
Humanitarian / disaster / event beachhead	Documentation tool + privacy compliance	Months
Training / simulation	Documentation tool (lowest risk)	Months
Official EMS (provincial/municipal)	Full SaMD + OADS/NEMSIS + QMS	12-24+ months